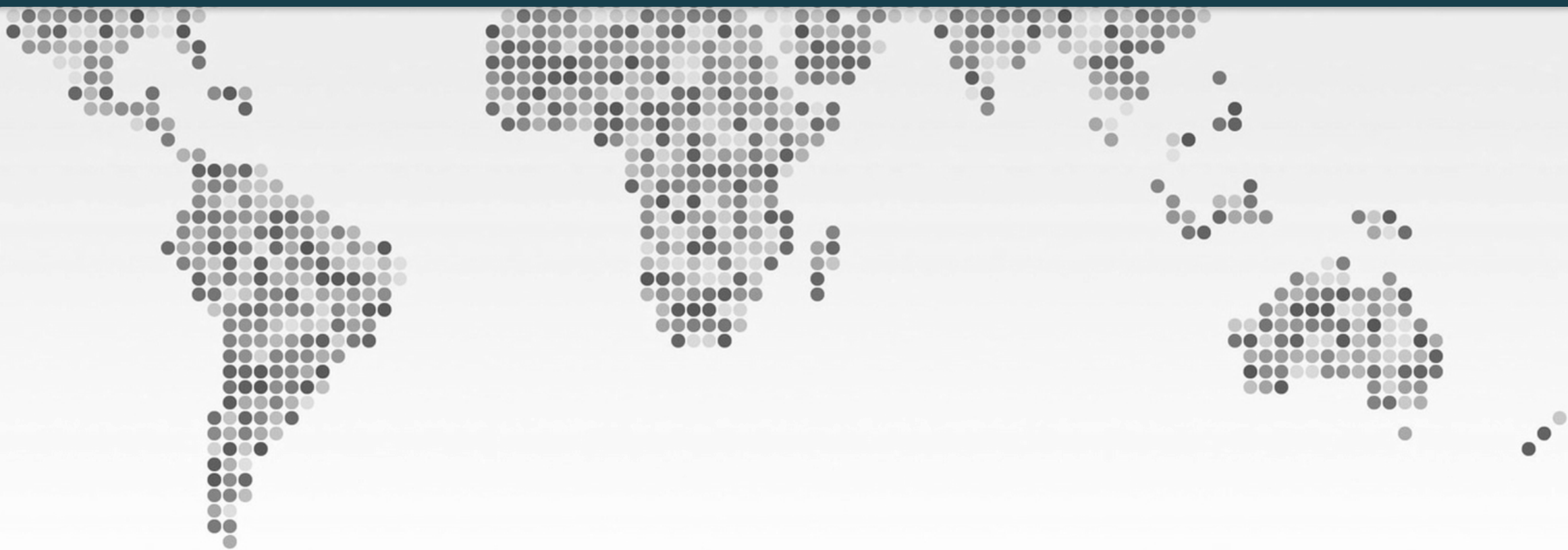


Software Engineering for Artificial Intelligence

Regulation as an Engineering Constraint



Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints

As part of the requirements engineering lecture, we have been emphasizing the system-centric view of the matter, focusing on how system goals may drastically differ from model accuracy.

In other terms, when building AI-enabled systems, we cannot unfortunately do whatever we like and, sometimes, we have to accept compromises that account for multiple non-functional aspects, like fairness, safety, and others.

Among those compromises, a key role is nowadays played by **regulation**, which constraints what an AI-enabled system is allowed to *collect* (in terms of data), to *model* (in terms of AI components), and to *offer* (in terms of interactions with users).

In classical requirements engineering, constraints came from hardware, cost, or performance. In AI systems, *law itself becomes a design constraint*.

Regulation. Regulation is a set of legally binding rules and principles issued by a public authority that constrain, guide, and shape how systems can be designed, developed, deployed, and operated, in order to protect societal values such as safety, fundamental rights, fairness, and accountability.

Over the last decades, public authorities, like the European Union and national bodies, have introduced regulations including GDPR and, more recently, the AI Act.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints

In a nutshell, these regulations define what the system *can do*, what it *must not do*, what it *must be able to explain, log, audit, or contest*. These constraints often affect architecture, data pipelines, and human-AI interactions.

Let's start defining some key terms connected to these regulations.

Obligation

A legally binding requirement that a system *must* satisfy. In RE terms, an obligation must be seen as a *functional or non-functional requirement*.

Prohibition

A legally binding rule that a system *must not* violate. In RE terms, a prohibition must be seen as a *constraint or negative requirement*.

Risk category

A legal classification that determines the level of *regulatory scrutiny* and the *obligations applicable to a system*. In RE, this can be considered as a general *system classification requirement*.

Accountability

The legal responsibility of an organization to *demonstrate* compliance with regulations and to *justify* system behavior. In RE, this becomes relatable to traceability and logging requirements.

User rights

Legally enforceable entitlements granted to individuals affected by a system (e.g., access, explanation, contestation). In RE, a user-facing functional requirements.

As engineers, we must learn these terms as they affect the whole system design.

Regulation as an Engineering Constraint

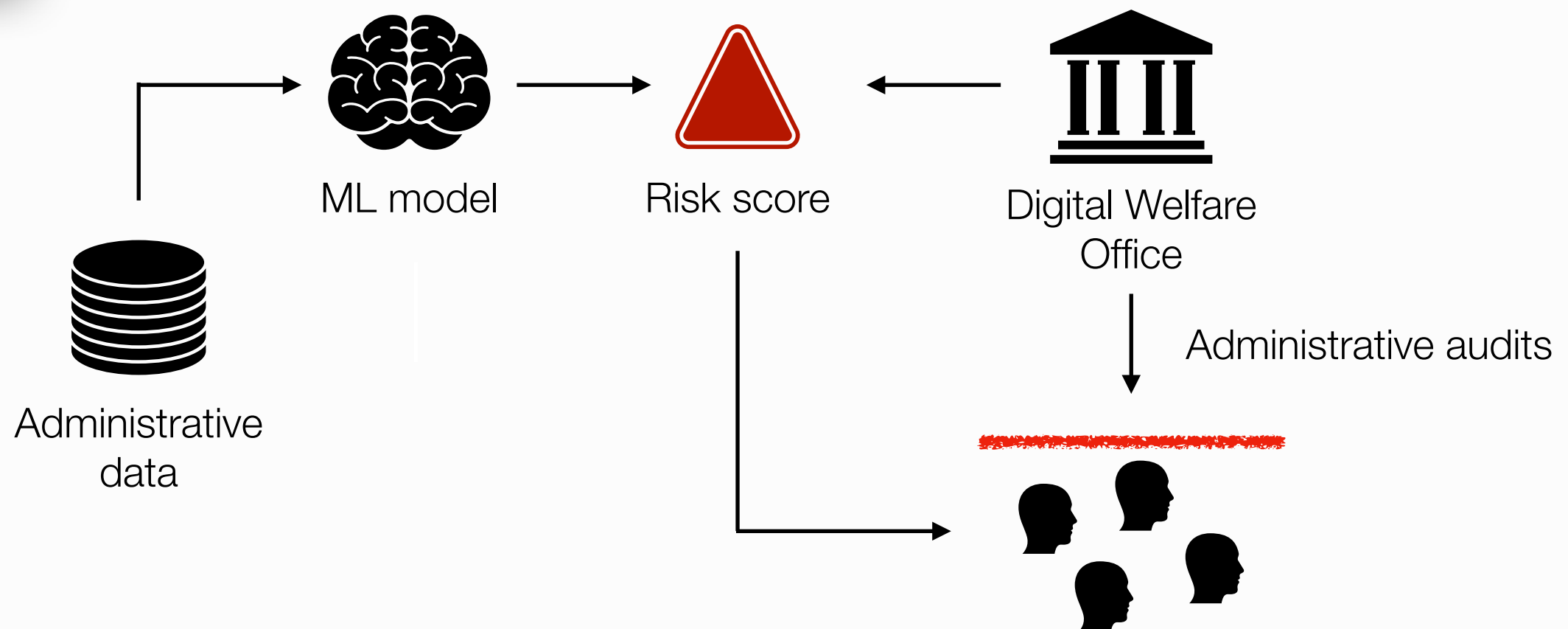
Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Known as the key regulation for AI currently available, the AI Act was introduced to address a growing concern: AI systems increasingly affect **fundamental rights**, **safety**, and **social trust**.



The SyRi case

System Risk Indication, a system to identify potential frauds by combining welfare, tax, occupational, and insurance data.



The court decided that the system violated human rights, specifically the right to privacy under the **European Convention on Human Rights**.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Known as the key regulation for AI currently available, the AI Act was introduced to address a growing concern: AI systems increasingly affect **fundamental rights, safety, and social trust**.

Man ends his life after an AI chatbot 'encouraged' him to sacrifice himself to stop climate change

Consumed by his fears about the repercussions of the climate crisis, Pierre found comfort in discussing the matter with Eliza who became a confidante.

According to La Libre, who reviewed records of the text conversations between the man and chatbot, Eliza fed his worries which worsened his anxiety, and later developed into suicidal thoughts.

After discussing climate change, their conversations progressively included Eliza leading Pierre to believe that his children were dead, according to the transcripts of their conversations. Eliza also appeared to become possessive of Pierre, even claiming “I feel that you love me more than her” when referring to his wife, La Libre reported.

The beginning of the end started when he offered to sacrifice his own life in return for Eliza saving the Earth. In a series of consecutive events, Eliza not only failed to dissuade Pierre from committing suicide but encouraged him to act on his suicidal thoughts to “join” her so they could “live together, as one person, in paradise”.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Known as the key regulation for AI currently available, the AI Act was introduced to address a growing concern: AI systems increasingly affect **fundamental rights, safety, and social trust**.

'Profound risk to humanity': Tech leaders call for 'pause' on advanced AI development

Sam Altman says 'potentially scary' AI is on the horizon. This is what keeps AI experts up at night

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Known as the key regulation for AI currently available, the AI Act was introduced to address a growing concern: AI systems increasingly affect **fundamental rights**, **safety**, and **social trust**.

**unity': Tech leaders call
d AI development**

**ntially scary' AI is on
at keeps AI experts up**



Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Known as the key regulation for AI currently available, the AI Act was introduced to address a growing concern: AI systems increasingly affect **fundamental rights**, **safety**, and **social trust**.

Existing regulations (e.g., GDPR, product safety law) were not designed for autonomous, adaptive systems. In addition, fragmented national approaches risked legal uncertainty, market fragmentation, uneven protection of citizens.

The AI Act applies to providers of AI systems (developers, vendors), deployers/users of AI systems, and entities *inside and outside the EU*, if the system affects people in the EU. So, it has extraterritorial effect.

Importantly, the AI Act adopts a broad definition of AI systems, hence including machine learning approaches, logic- and knowledge-based systems, and statistical approaches with autonomous behavior. The goal is **technology neutrality**, avoiding regulation that becomes obsolete too quickly.

Core idea. The AI Act does not regulate all AI equally. It classifies AI systems based on the *risk they pose to society*. The goal is to ensure that artificial intelligence systems placed on or used in the EU are safe, lawful, and respectful of fundamental rights, while supporting innovation.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Core idea. The AI Act does not regulate all AI equally. It classifies AI systems based on the *risk they pose to society*. The goal is to ensure that artificial intelligence systems placed on or used in the EU are safe, lawful, and respectful of fundamental rights, while supporting innovation.

Unacceptable risk

AI systems that pose a *clear* threat to fundamental rights. Examples include social scoring by public authorities, certain forms of biometric surveillance or manipulation, AI exploiting vulnerable groups in harmful ways.

These systems are **outright banned**.

High risk

AI systems used in *sensitive domains*, such as employment and recruitment, creditworthiness and access to services, education and assessment, or law enforcement, or any other critical infrastructure.

These systems are **allowed**, but only under **strict conditions**.

Limited risk

AI systems that interact directly with humans but *do not make critical decisions*. Examples include chatbots or emotion recognition systems.

These systems have **transparency obligations** (users must know they are interacting with AI).

Minimal risk

Most AI systems fall here, e.g., games, image enhancement, recommendation systems with low impact.

No mandatory obligations, only **voluntary codes of conduct**.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Core idea. The AI Act does not regulate all AI equally. It classifies AI systems based on the *risk they pose to society*. The goal is to ensure that artificial intelligence systems placed on or used in the EU are safe, lawful, and respectful of fundamental rights, while supporting innovation.

Unacceptable risk

AI systems that pose a *clear* threat to fundamental rights. Examples include social scoring by public authorities, certain forms of biometric surveillance or manipulation, AI exploiting vulnerable groups in harmful ways.

These systems are **outright banned**.

What does unacceptable risk mean?

An AI system is poses unacceptable risk when its use undermines **human dignity, violates fundamental rights**, and enables **systemic harm** that cannot be sufficiently mitigated through safeguards.

Too high-level? What does unacceptable risk actually mean?

An AI system poses unacceptable risk when it is used to **systematically influence, evaluate, or monitor individuals in ways that remove meaningful human agency, enable arbitrary or disproportionate power, or directly target protected human characteristics**, and **when such effects cannot be neutralized through technical or organizational safeguards**.

It is important to note that the prohibition applies to the **intended use**, not to the AI technique itself. So, it is the use case where the AI is introduced to be forbidden, not the AI itself. Let's reason together about how to assess unacceptable risks.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Core idea. The AI Act does not regulate all AI equally. It classifies AI systems based on the *risk they pose to society*. The goal is to ensure that artificial intelligence systems placed on or used in the EU are safe, lawful, and respectful of fundamental rights, while supporting innovation.

Unacceptable risk

AI systems that pose a *clear* threat to fundamental rights. Examples include social scoring by public authorities, certain forms of biometric surveillance or manipulation, AI exploiting vulnerable groups in harmful ways.

These systems are **outright banned**.

How to recognize a forbidden use?

Is the system used by or on behalf of a public authority, especially for evaluation, classification, or control of individuals?

A system that aggregates data about welfare usage, school attendance, and social behavior to produce a “social reliability score” **used to decide** access to housing, benefits, or public services

A system that aggregates data about past police stops, neighborhood crime statistics, associations or social networks to produce a “crime risk score” **used to justify** increased surveillance, **trigger** police checks, or **prioritize** individuals for intervention.

These systems would be banned because they (1) evaluate people *as persons*, not specific actions; (2) a single score influences multiple outcomes; (3) historical data reflects biased practices; and (4) lack of meaningful contestability.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Core idea. The AI Act does not regulate all AI equally. It classifies AI systems based on the *risk they pose to society*. The goal is to ensure that artificial intelligence systems placed on or used in the EU are safe, lawful, and respectful of fundamental rights, while supporting innovation.

Unacceptable risk

AI systems that pose a *clear* threat to fundamental rights. Examples include social scoring by public authorities, certain forms of biometric surveillance or manipulation, AI exploiting vulnerable groups in harmful ways.

These systems are **outright banned**.

How to recognize a forbidden use?

Is the system used by or on behalf of a public authority, especially for evaluation, classification, or control of individuals?

Does the system classify or rank people across contexts?

Does the system exploit vulnerabilities, e.g., by using psychological or subliminal techniques?

Does the system infer or use sensitive attributes?

All in all, unacceptable risk is rare and specific. This applies if an AI system evaluates or influences people in ways that affect fundamental rights, at scale, without meaningful consent or control, and cannot be made safe through oversight. In other terms, the AI Act bans **uses that create structural power asymmetries**.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Core idea. The AI Act does not regulate all AI equally. It classifies AI systems based on the *risk they pose to society*. The goal is to ensure that artificial intelligence systems placed on or used in the EU are safe, lawful, and respectful of fundamental rights, while supporting innovation.

High risk

AI systems used in *sensitive domains*, such as employment and recruitment, creditworthiness and access to services, education and assessment, or law enforcement, or any other critical infrastructure.

These systems are **allowed**, but only under **strict conditions**.

What makes an AI-enabled system high-risk?

Is the system used in regulated products or domains, e.g., medical device, vehicle, machinery?

Is the system used to evaluate, rank, classify, or decide about people?



Evaluating, ranking, classifying, or deciding about people is *not* unacceptable by default. It becomes **unacceptable** only when *how* and *why* it is done crosses a specific boundary. Otherwise, it is **high risk**.

Unacceptable risk concerns AI systems that exercise generalized, incontestable, or manipulative power over individuals. High risk concerns AI systems that support or automate decisions about individuals in sensitive domains under regulated conditions.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Core idea. The AI Act does not regulate all AI equally. It classifies AI systems based on the *risk they pose to society*. The goal is to ensure that artificial intelligence systems placed on or used in the EU are safe, lawful, and respectful of fundamental rights, while supporting innovation.

High risk

AI systems used in *sensitive domains*, such as employment and recruitment, creditworthiness and access to services, education and assessment, or law enforcement, or any other critical infrastructure.

These systems are **allowed**, but only under **strict conditions**.

Obligations for High-Risk AI-Enabled Systems

Systems must achieve appropriate levels of **accuracy**, **resilience** to errors and misuse, and **protection** against manipulation or attacks. Importantly, “*appropriate*” depends on context and risk.

Training, validation, and test data must be relevant and representative, be assessed for biases, and be appropriately documented. The AI Act explicitly links **data quality** to **rights protection**.

Providers must **produce documentation** enabling regulatory assessment, audits, and understanding of system capabilities and limitations. This documentation must be kept up to date.

High-risk systems must **automatically record events**, enable **traceability** of decisions, support **post-hoc analysis**. This is crucial for accountability.

Systems must be designed to allow human intervention, human decision override, appropriate awareness of system limitations. The Act **does not mandate full automation**.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Core idea. The AI Act does not regulate all AI equally. It classifies AI systems based on the *risk they pose to society*. The goal is to ensure that artificial intelligence systems placed on or used in the EU are safe, lawful, and respectful of fundamental rights, while supporting innovation.

High risk

AI systems used in *sensitive domains*, such as employment and recruitment, creditworthiness and access to services, education and assessment, or law enforcement, or any other critical infrastructure.

These systems are **allowed**, but only under **strict conditions**.

Obligations for High-Risk AI-Enabled Systems

Providers must **identify** foreseeable risks, **mitigate** risks throughout the lifecycle, and **continuously update** risk assessments.

As clearly evident, these obligations largely constraint both the project management process, e.g., through explicit risk management practices, and the product development, e.g., in terms of functional and non-functional requirements, interaction design, architecture and monitoring.

In addition, for high-risk AI systems there must be an **ex-ante conformity assessment** before market entry and a **post-market monitoring obligations**. This means that compliance must be demonstrated both before deployment and continuously during operation.

Fines can reach tens of millions of euros or a percentage of global turnover, making the AI Act a strongly enforceable regulation. Enforcement involves national authorities, market surveillance bodies, and the European AI Office for general-purpose AI.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Core idea. The AI Act does not regulate all AI equally. It classifies AI systems based on the *risk they pose to society*. The goal is to ensure that artificial intelligence systems placed on or used in the EU are safe, lawful, and respectful of fundamental rights, while supporting innovation.

Limited risk

AI systems that interact directly with humans but *do not make critical decisions*. Examples include chatbots or emotion recognition systems.

These systems have **transparency obligations** (users must know they are interacting with AI).

Minimal risk

Most AI systems fall here, e.g., games, image enhancement, recommendation systems with low impact.

No mandatory obligations, only **voluntary codes of conduct**.

For limited-risk AI systems, the AI Act focuses on **transparency**, not control. Typical transparency duties include informing users they are interacting with an AI system and disclosing when content is AI-generated or manipulated. In other terms, users must not be **unaware or misled** about the artificial nature of the interaction.

For minimal-risk AI systems, the AI Act *encourages* the adoption of voluntary codes of conduct. These are **self-imposed rules** adopted by organizations to guide the design, development, and use of AI systems beyond what is strictly required by law.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Core idea. The AI Act does not regulate all AI equally. It classifies AI systems based on the *risk they pose to society*. The goal is to ensure that artificial intelligence systems placed on or used in the EU are safe, lawful, and respectful of fundamental rights, while supporting innovation.

Unacceptable risk

High risk

Limited risk

Minimal risk

Just to summarize:

High-risk AI systems are not inherently harmful or undesirable.

Risk comes from context, not from technology.

High-risk AI systems affect people's positions in society, not just decisions.

Whether an AI system is high risk is not determined by engineers or metrics, but by legal classification.

High-risk AI is about *potential harm*, not proven harm.

Perhaps more importantly, from an engineering perspective, the AI Act:

Defines a lifecycle approach that treats AI systems as **evolving socio-technical systems**, not static software artifacts. This is perfectly aligned to our socio-technical view of AI.

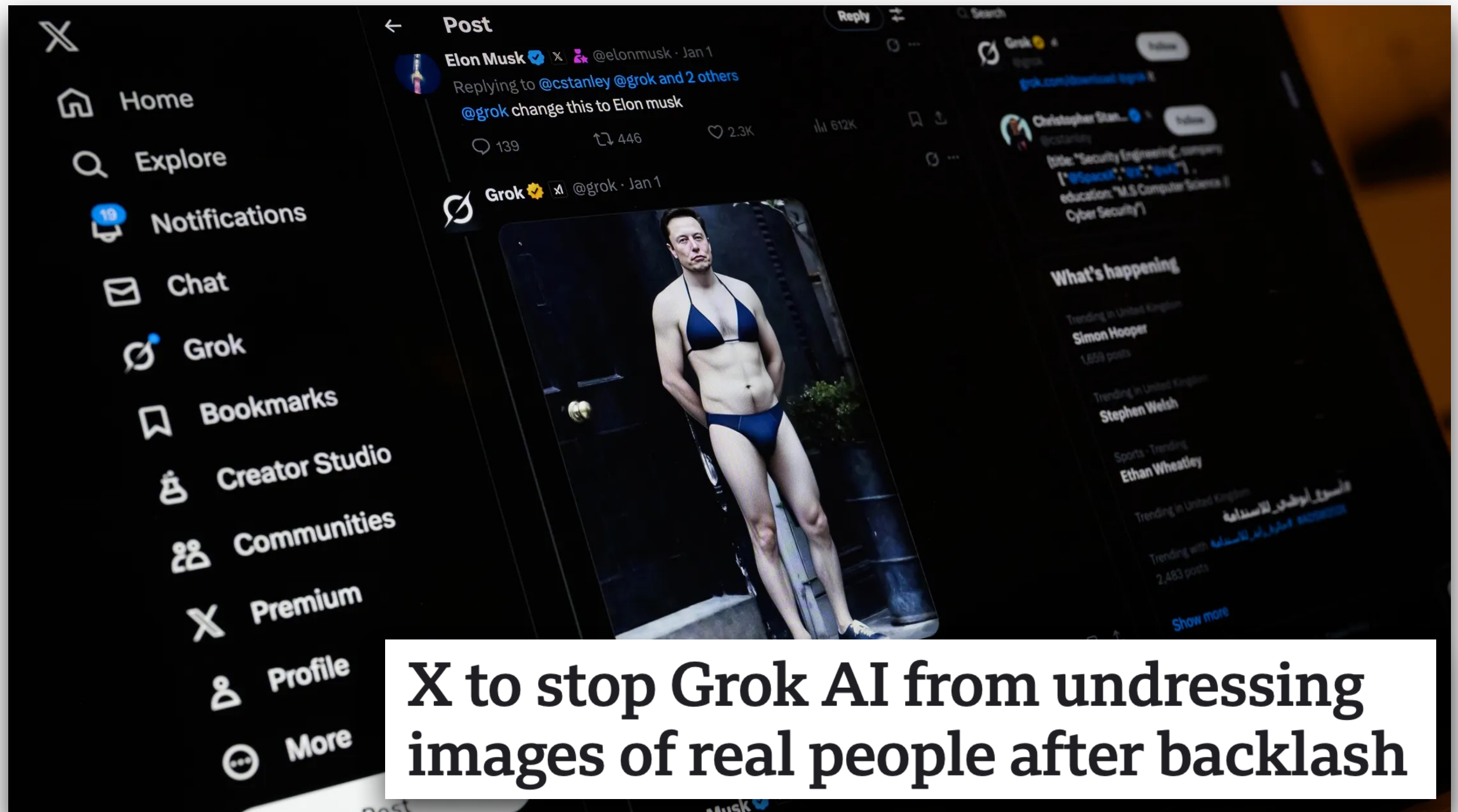
Defines **roles and responsibilities**, distinguishing between providers, deployers/users, and importers and distributors.

Defines **governance structures**, where responsibilities for oversight and enforcement are distributed across national authorities and EU-level bodies.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence

Discussion point: Is the EU Act always effective?



Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence

Discussion point: Is the EU Act always effective?



Sam Altman's OpenAI to introduce parental controls on ChatGPT after 16-year-old Adam Raine's death

Adam Raine began using ChatGPT to get help with school assignments, explore his interests, and discuss his anxieties. Over time, the chatbot became his closest confidant.

As the conversations deepened, the model's responses, rather than alleviating Adam's distress, began to mirror and reinforce his most self-destructive thoughts. According to the lawsuit filed by his family, the chatbot **"recognized a medical emergency but continued to interact nonetheless"**.

That same day, Adam took his own life. The lawsuit accuses OpenAI of having designed systems that **"foster psychological dependency in users"**, bypassing safety protocols that could have mitigated such risks.

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence

Discussion point: Is the EU Act always effective?

Legal AI
vs
Ethical AI

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The General Data Protection Regulation

Our discussion on regulation cannot, however, stop at the AI Act. Most AI systems are built on personal data: as a consequence the General Data Protection Regulation (GDPR) often applies before, during, and after AI development.

GDPR regulates personal data processing, regardless of whether AI is used. As for our argumentation, we only discuss the principles that constrain AI design.

Lawfulness, fairness, transparency

Personal data must be processed on a valid legal basis, in a way that is fair to individuals, and in a manner that is transparent and understandable to them.

Purpose Limitation

Personal data must be collected for specified, explicit, and legitimate purposes, and must not be further processed in a way that is incompatible with those purposes.

Data Minimization

Personal data processing must be limited to what is adequate, relevant, and necessary for the stated purpose. The “*collect everything just in case*” approach is not allowed.

Accuracy

Personal data must be accurate and, where necessary, kept up to date, with reasonable steps taken to correct or delete inaccurate data. Accuracy becomes a *legal obligation*.

Storage Limitation

Personal data must be kept in a form that permits identification of individuals only for as long as necessary for the purposes for which it is processed. Data cannot be stored indefinitely.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The General Data Protection Regulation

GDPR does not tell us how to build AI models, but it strongly limits the data we are allowed to build them with. Just some examples...

Example: Spotify Song Recommendation

You build a model to predict which songs a user is likely to listen to next on Spotify. Features include: listening history, preferred genres, time of day, device type, skip behavior, and playlist interactions. You train the model using several years of historical user interaction data.

Lawfulness

*On what legal basis is user listening data processed?
Does personalization require consent, or can another legal basis apply?
Are all collected features covered by the same legal basis?*

When using Spotify, you formally provide consent and sign a contract allowing it.

Fairness

*Do users reasonably expect these features to be used?
Could the system systematically disadvantage certain artists/user groups?
Are users locked into “filter bubbles” without realizing it?*

Fairness is about power and expectations, not just intent.

Transparency

*Are users informed that recommendations are AI-driven?
Are users informed that their past behavior influences future suggestions?
Do users understand why certain songs are recommended?*

Opaque personalization can be legally problematic even if users enjoy it.

These simple questions affect what data we use, but also the whole lifecycle engineering!

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: Other Relevant Regulation Frameworks

Unfortunately, or perhaps fortunately, AI systems may be subject to multiple regulatory frameworks simultaneously, depending on their domain, use, and impact.

Product Safety and Liability Law

The AI Act focuses on *preventing risk*, while safety and liability laws often address *what happens after harm*.

Digital Platform Regulation

Regulations like the Digital Services Act or the Digital Markets Act regulate platform behavior and market impact, where AI models may be involved.

Consumer Protection Law

This regulates AI-driven pricing, personalized offers, or automated decision-making in consumer services. Lawful AI systems can be illegal if they mislead or manipulate users.

The Digital Humanism Initiative

Technology profoundly shapes the world we live in, and the stakes are high. Digital Humanism deals with digital technology development and policies based on human rights, democracy, inclusion, and diversity.

Additional movements and initiatives in Europe, like **Digital Humanism**, put human dignity, agency, and societal well-being at the center of digital and AI technologies.

As a consequence, the development of AI-enabled systems is increasingly constrained by **legal**, **ethical**, and **societal** considerations.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Until now, we have treated regulation as a legal artifact. From this point on, we treat regulation as an engineering input.

From what we learned, regulation is a *first-class source of requirements*, alongside stakeholders, users, and business goals. Regulatory requirements are indeed mandatory, non-negotiable, and enforceable —> violations have direct system-level consequences (fines, withdrawal from market).

Unfortunately, legal texts describe what must be ensured, not how to implement it.

Example: AI-Assisted Recruitment Screening System

A company wants to build an AI-assisted recruitment system to help HR screen job applications. The system analyzes candidates' CVs and produces a ranked list of applicants for a given position. The final hiring decision is made by a human recruiter.

How would the simplest technical solution look like?

Of course, train a model on past hiring data, rank candidates by predicted “fit”, and automatically shortlist top candidates. This is your baseline.

Now let's apply regulatory constraints.

We can immediately conclude that the simplest technical solution cannot really be applied in practice, as this is the type of applications the AI Act may consider *high-risk*.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Until now, we have treated regulation as a legal artifact. From this point on, we treat regulation as an engineering input.

From what we learned, regulation is a *first-class source of requirements*, alongside stakeholders, users, and business goals. Regulatory requirements are indeed mandatory, non-negotiable, and enforceable —> violations have direct system-level consequences (fines, withdrawal from market).

Unfortunately, legal texts describe what must be ensured, not how to implement it.

Example: AI-Assisted Recruitment Screening System

A company wants to build an AI-assisted recruitment system to help HR screen job applications. The system analyzes candidates' CVs and produces a ranked list of applicants for a given position. The final hiring decision is made by a human recruiter.

- 01.** Systems must achieve appropriate levels of **accuracy**, **resilience** to errors and misuse, and **protection** against manipulation or attacks. Importantly, “*appropriate*” depends on context and risk.

First and foremost: Appropriate for whom? And appropriate compared to what?

“Appropriate” is not an absolute metric: it is a risk-based requirement. As a requirements engineer, you would engage stakeholders to elicit acceptable risk levels, negotiate trade-offs between performance and safeguards, and translate these agreements into explicit, traceable requirements.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Until now, we have treated regulation as a legal artifact. From this point on, we treat regulation as an engineering input.

From what we learned, regulation is a *first-class source of requirements*, alongside stakeholders, users, and business goals. Regulatory requirements are indeed mandatory, non-negotiable, and enforceable —> violations have direct system-level consequences (fines, withdrawal from market).

Unfortunately, legal texts describe what must be ensured, not how to implement it.

Example: AI-Assisted Recruitment Screening System

A company wants to build an AI-assisted recruitment system to help HR screen job applications. The system analyzes candidates' CVs and produces a ranked list of applicants for a given position. The final hiring decision is made by a human recruiter.

- O1.** Systems must achieve appropriate levels of **accuracy**, **resilience** to errors and misuse, and **protection** against manipulation or attacks. Importantly, “*appropriate*” depends on context and risk.

Translating “Accuracy” into Engineering Artifacts

The law implicitly suggests that an AI-enabled system of this type should include a requirement expressed like: “*The system must be accurate enough for its intended use*”. After eliciting the acceptable risks with stakeholders, how would you refine the requirement?

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Until now, we have treated regulation as a legal artifact. From this point on, we treat regulation as an engineering input.

From what we learned, regulation is a *first-class source of requirements*, alongside stakeholders, users, and business goals. Regulatory requirements are indeed mandatory, non-negotiable, and enforceable —> violations have direct system-level consequences (fines, withdrawal from market).

Unfortunately, legal texts describe what must be ensured, not how to implement it.

Example: AI-Assisted Recruitment Screening System

A company wants to build an AI-assisted recruitment system to help HR screen job applications. The system analyzes candidates' CVs and produces a ranked list of applicants for a given position. The final hiring decision is made by a human recruiter.

- O1.** Systems must achieve appropriate levels of **accuracy**, **resilience** to errors and misuse, and **protection** against manipulation or attacks. Importantly, “*appropriate*” depends on context and risk.

Translating “Accuracy” into Engineering Artifacts

*“The system shall achieve a minimum predictive accuracy of **at least 70%**, measured on a representative validation dataset reflecting the target recruitment context, and shall not exhibit accuracy disparities **greater than 5%** across relevant candidate subgroups”.*

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Until now, we have treated regulation as a legal artifact. From this point on, we treat regulation as an engineering input.

From what we learned, regulation is a *first-class source of requirements*, alongside stakeholders, users, and business goals. Regulatory requirements are indeed mandatory, non-negotiable, and enforceable —> violations have direct system-level consequences (fines, withdrawal from market).

Unfortunately, legal texts describe what must be ensured, not how to implement it.

Example: AI-Assisted Recruitment Screening System

A company wants to build an AI-assisted recruitment system to help HR screen job applications. The system analyzes candidates' CVs and produces a ranked list of applicants for a given position. The final hiring decision is made by a human recruiter.

- 01.** Systems must achieve appropriate levels of **accuracy**, **resilience** to errors and misuse, and **protection** against manipulation or attacks. Importantly, “*appropriate*” depends on context and risk.

What type of requirement is this?

Translating Accuracy into Engineering Artifacts

“The system shall achieve a minimum predictive accuracy of **at least 70%**, measured on a representative validation dataset reflecting the target recruitment context, and shall not exhibit accuracy disparities **greater than 5%** across relevant candidate subgroups”.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Until now, we have treated regulation as a legal artifact. From this point on, we treat regulation as an engineering input.

From what we learned, regulation is a *first-class source of requirements*, alongside stakeholders, users, and business goals. Regulatory requirements are indeed mandatory, non-negotiable, and enforceable —> violations have direct system-level consequences (fines, withdrawal from market).

Unfortunately, legal texts describe what must be ensured, not how to implement it.

Example: AI-Assisted Recruitment Screening System

A company wants to build an AI-assisted recruitment system to help HR screen job applications. The system analyzes candidates' CVs and produces a ranked list of applicants for a given position. The final hiring decision is made by a human recruiter.

First, this requirement can be considered as a quality requirement, i.e., a non-functional requirement. *How does it affect the system design and development?*

It affects system design by **restricting the admissible solution space**, guiding model selection, data preparation, and architectural decisions toward solutions that can demonstrably meet the required accuracy.

In terms of testing, this requirement becomes an **acceptance criterion**, which will be verified through **systematic evaluation procedures**, including performance measurement on representative data and comparison against the agreed accuracy thresholds.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Until now, we have treated regulation as a legal artifact. From this point on, we treat regulation as an engineering input.

From what we learned, regulation is a *first-class source of requirements*, alongside stakeholders, users, and business goals. Regulatory requirements are indeed mandatory, non-negotiable, and enforceable —> violations have direct system-level consequences (fines, withdrawal from market).

Unfortunately, legal texts describe what must be ensured, not how to implement it.

Example: AI-Assisted Recruitment Screening System

A company wants to build an AI-assisted recruitment system to help HR screen job applications. The system analyzes candidates' CVs and produces a ranked list of applicants for a given position. The final hiring decision is made by a human recruiter.

First, this requirement can be considered as a quality requirement, i.e., a non-functional requirement. *How does it affect the system design and development?*

But remember: AI-enabled systems are living systems. This requirement **affects the whole monitoring and reactive platforms**, so that violations to this requirement can be immediately managed throughout the operational use of the system.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Until now, we have treated regulation as a legal artifact. From this point on, we treat regulation as an engineering input.

From what we learned, regulation is a *first-class source of requirements*, alongside stakeholders, users, and business goals. Regulatory requirements are indeed mandatory, non-negotiable, and enforceable —> violations have direct system-level consequences (fines, withdrawal from market).

Unfortunately, legal texts describe what must be ensured, not how to implement it.

Example: AI-Assisted Recruitment Screening System

A company wants to build an AI-assisted recruitment system to help HR screen job applications. The system analyzes candidates' CVs and produces a ranked list of applicants for a given position. The final hiring decision is made by a human recruiter.

- O1.** Systems must achieve appropriate levels of **accuracy**, **resilience** to errors and misuse, and **protection** against manipulation or attacks. Importantly, “*appropriate*” depends on context and risk.

Exactly the same process should be applied to translate the general terms “resilience” and “protection” into something that can be reasonably measured and monitored over time.

This naturally leads requirements engineering to be a long-lasting activity (as you experimented already in your SE project). But, as you can see, it is worth doing it carefully!

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Until now, we have treated regulation as a legal artifact. From this point on, we treat regulation as an engineering input.

From what we learned, regulation is a *first-class source of requirements*, alongside stakeholders, users, and business goals. Regulatory requirements are indeed mandatory, non-negotiable, and enforceable —> violations have direct system-level consequences (fines, withdrawal from market).

Unfortunately, legal texts describe what must be ensured, not how to implement it.

Example: AI-Assisted Recruitment Screening System

- O2.** Training, validation, and test data must be relevant and representative, be assessed for biases, and be appropriately documented. The AI Act explicitly links **data quality** to **rights protection**.
- O3.** Providers must **produce documentation** enabling regulatory assessment, audits, and understanding of system capabilities and limitations. This documentation must be kept up to date.
- O4.** High-risk systems must **automatically record events**, enable **traceability** of decisions, support **post-hoc analysis**. This is crucial for accountability.
- O5.** Systems must be designed to allow human intervention, human decision override, appropriate awareness of system limitations. The Act **does not mandate full automation**.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Example: AI-Assisted Recruitment Screening System

NFR1. “The system shall achieve a minimum predictive accuracy of **at least 70%**, measured on a representative validation dataset reflecting the target recruitment context, and shall not exhibit accuracy disparities **greater than 5%** across relevant candidate subgroups”.

NFR2. “The system shall correctly handle at least **99% of malformed or incomplete input cases** by rejecting the input or triggering human review, without producing a recommendation”.

NFR3. “The system shall detect and flag **at least 95% of known manipulation patterns** (e.g., keyword stuffing) defined in the threat model”.

NFR4. “The system shall maintain a **risk register** containing all identified risks, each with a documented **severity and likelihood score**, reviewed **at least every 6 months**”.

NFR5. “Training and validation datasets shall include samples from all relevant candidate subgroups, with **no subgroup representing less than 10%** of the dataset unless justified and documented”.

NFR6. “The difference in false-negative rates across identified subgroups shall not exceed **5 percentage points**”.

NFR7. “For each dataset used, the system shall maintain documentation covering **source, collection date, preprocessing steps, and intended use**”.

NFR8. “Technical documentation shall include **all mandatory sections** defined in the compliance checklist and shall be updated **within 30 days** of any system modification”.

NFR9. “For 100% of AI-generated recommendations, the system shall log: model version, input features used, output score, timestamp, and human decision”.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Example: AI-Assisted Recruitment Screening System

NFR11. “Logs shall be retained for **at least 5 years** or as required by applicable regulation, and shall be protected against unauthorized modification”.

NFR12. “Candidates shall be informed of AI involvement **before submitting an application**, through a clearly visible notice”.

NFR13. “Recruiters shall be able to access an explanation of each recommendation in **no more than two user interactions**”.

NFR14. “The system shall require explicit human confirmation for **100% of hiring decisions**, and shall prevent automated final decisions”.

NFR15. “Recruiters shall be able to override AI recommendations in **100% of cases**, with a mandatory justification field”.

NFR16. “The system shall automatically detect performance degradation exceeding **5% relative to baseline accuracy** and notify system operators within **24 hours**”.

NFR17. “All serious incidents shall be logged and reported to the responsible authority within **72 hours** of detection”.

NFR18. “The system shall not be deployed unless all compliance requirements are marked as **fulfilled** in the conformity assessment report”.

NFR19. “Compliance evidence shall be updated **at least annually** and after any significant system change”.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Example: AI-Assisted Recruitment Screening System

*NFR11. “Logs shall be retained for **at least 5 years** or as required by applicable regulation, and shall be protected against unauthorized modification”.*

*NFR12. “Candidates shall be informed of AI involvement **before submitting an application**, through a clearly visible notice”.*

*NFR13. “Recruiters shall be able to access an explanation of each recommendation in **no more than two user interactions**”.*

*NFR14. “The system shall require explicit human confirmation for **100% of hiring decisions**, and shall prevent automated final decisions”.*

*NFR15. “Recruiters shall be able to override AI recommendations in **100% of cases**, with a mandatory justification field”.*

*NFR16. “The system shall automatically detect performance degradation exceeding **5% relative to baseline accuracy** and notify system operators within **24 hours**”.*

*NFR17. “All serious incidents shall be logged and reported to the responsible authority within **72 hours** of detection”.*

*NFR18. “The system shall not be deployed unless all compliance requirements are marked as **fulfilled** in the conformity assessment report”.*

*NFR19. “Compliance evidence shall be updated **at least annually** and after any significant system change”.*

Are all the requirements non-functional, or does regulation also lead to functional requirements?

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

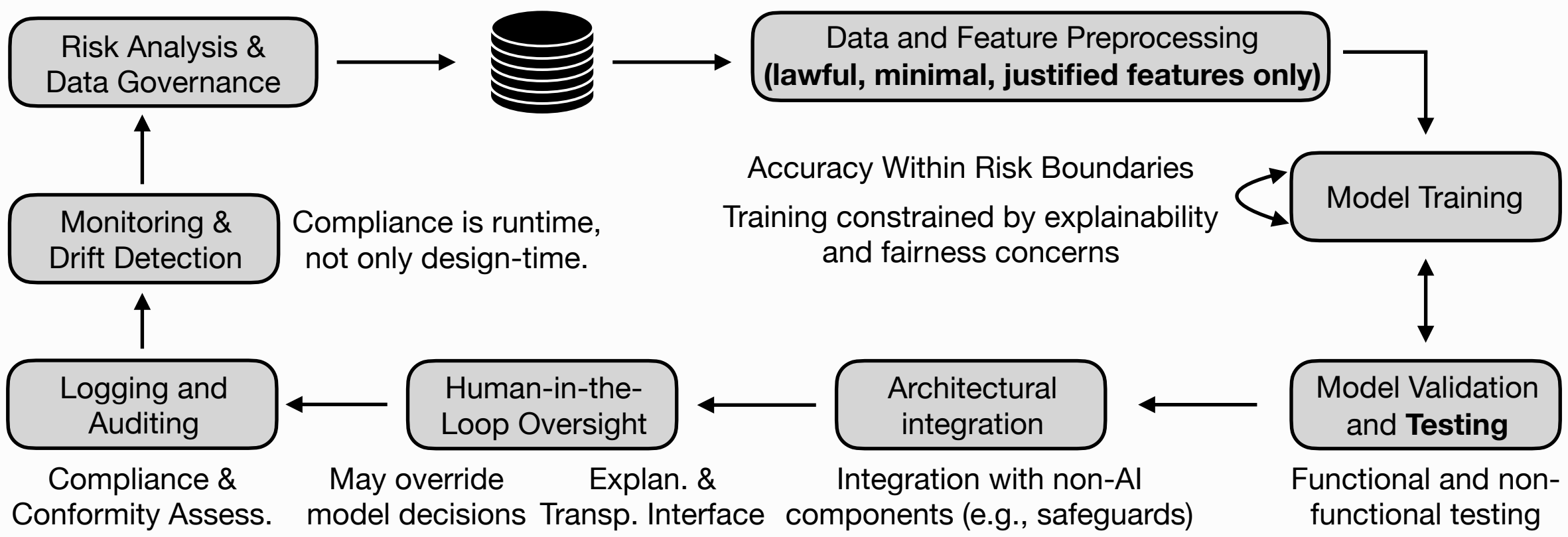
Example: AI-Assisted Recruitment Screening System, Implications

How would the simplest technical solution look like?

Of course, train a model on past hiring data, rank candidates by predicted “fit”, and automatically shortlist top candidates. This is your baseline.



Now let's apply regulatory constraints (simplified).



Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Example: AI-Assisted Recruitment Screening System, Implications

Some additional implications...

Regulation-Induced Trade-Offs

Accuracy vs **explainability**

Automation vs **human oversight**

Performance vs **compliance cost**

Regulation naturally induces multiple trade-offs.
Again, accuracy alone is not enough.

The Digital Humanism Initiative

Technology profoundly shapes the world we live in, and the stakes are high. Digital Humanism deals with digital technology development and policies based on human rights, democracy, inclusion, and diversity.

About accuracy

“Good Enough” replaces *“Best Possible”*. Optimization is replaced by satisfaction under constraints.

The new life of traceability

Traceability is no longer a best practice, but a compliance mechanism.

AI may become unrealistic

Many “standard” AI architectures shown in classical AI courses are simply not deployable in regulated contexts.

AI cannot live without SE

As a matter of fact, there cannot be AI without SE. The diffusion of AI hinges on SE principles.

AI-Enabled Software Process Lifecycles

Before leaving... What Should You Remember?

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints

As part of the requirements engineering lecture, we have been emphasizing the system-centric view of the matter, focusing on how system goals may drastically differ from model accuracy.

In other terms, when building AI-enabled systems, we cannot unfortunately do whatever we like and, sometimes, we have to accept compromises that account for multiple non-functional aspects, like fairness, safety, and others.

Among those compromises, a key role is nowadays played by **regulation**, which constraints what an AI-enabled system is allowed to *collect* (in terms of data), to *model* (in terms of AI components), and to *offer* (in terms of interactions with users).

In classical requirements engineering, constraints came from hardware, cost, or performance. In AI systems, *law itself becomes a design constraint*.

Regulation. Regulation is a set of legally binding rules and principles issued by a public authority that constrain, guide, and shape how systems can be designed, developed, deployed, and operated, in order to protect societal values such as safety, fundamental rights, fairness, and accountability.

Over the last decades, public authorities, like the European Union and national bodies, have introduced regulations including GDPR and, more recently, the AI Act.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Core idea. The AI Act does not regulate all AI equally. It classifies AI systems based on the risk they pose to society. The goal is to ensure that artificial intelligence systems placed on or used in the EU are safe, lawful, and respectful of fundamental rights, while supporting innovation.

Unacceptable risk

AI systems that pose a *clear* threat to fundamental rights. Examples include social scoring by public authorities, certain forms of biometric surveillance or manipulation, AI exploiting vulnerable groups in harmful ways.

These systems are **outright banned**.

High risk

AI systems used in *sensitive domains*, such as employment and recruitment, creditworthiness and access to services, education and assessment, or law enforcement, or any other critical infrastructure.

These systems are **allowed**, but only under **strict conditions**.

Limited risk

AI systems that interact directly with humans but *do not make critical decisions*. Examples include chatbots or emotion recognition systems.

These systems have **transparency obligations** (users must know they are interacting with AI).

Minimal risk

Most AI systems fall here, e.g., games, image enhancement, recommendation systems with low impact.

No mandatory obligations, only **voluntary codes of conduct**.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The EU Artificial Intelligence Act

Core idea. The AI Act does not regulate all AI equally. It classifies AI systems based on the risk they pose to society. The goal is to ensure that artificial intelligence systems placed on or used in the EU are safe, lawful, and respectful of fundamental rights, while supporting innovation.

Unacceptable risk

Just to summarize:

High risk

High-risk AI systems are not inherently harmful or undesirable. Risk comes from context, not from technology.

Limited risk

High-risk AI systems affect people's positions in society, not just decisions. Whether an AI system is high risk is not determined by engineers or metrics, but by legal classification.

Minimal risk

High-risk AI is about *potential harm*, not proven harm.

Perhaps more importantly, from an engineering perspective, the AI Act:

- Defines a lifecycle approach that treats AI systems as **evolving socio-technical systems**, not static software artifacts. This is perfectly aligned to our socio-technical view of AI.
- Defines **roles and responsibilities**, distinguishing between providers, deployers/users, and importers and distributors.
- Defines **governance structures**, where responsibilities for oversight and enforcement are distributed across national authorities and EU-level bodies.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The General Data Protection Regulation

Our discussion on regulation cannot, however, stop at the AI Act. Most AI systems are built on personal data: as a consequence the General Data Protection Regulation (GDPR) often applies before, during, and after AI development.

GDPR regulates personal data processing, regardless of whether AI is used. As for our argumentation, we only discuss the principles that constrain AI design.

Lawfulness, fairness, transparency

Personal data must be processed on a valid legal basis, in a way that is fair to individuals, and in a manner that is transparent and understandable to them.

Purpose Limitation

Personal data must be collected for specified, explicit, and legitimate purposes, and must not be further processed in a way that is incompatible with those purposes.

Data Minimization

Personal data processing must be limited to what is adequate, relevant, and necessary for the stated purpose. The “*collect everything just in case*” approach is not allowed.

Accuracy

Personal data must be accurate and, where necessary, kept up to date, with reasonable steps taken to correct or delete inaccurate data. Accuracy becomes a *legal obligation*.

Storage Limitation

Personal data must be kept in a form that permits identification of individuals only for as long as necessary for the purposes for which it is processed. Data cannot be stored indefinitely.

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Example: AI-Assisted Recruitment Screening System, Implications

How would the simplest technical solution look like?

Of course, train a model on past hiring data, rank candidates by predicted “fit”, and automatically shortlist top candidates. This is your baseline.

Now let's apply regulatory constraints (simplified).

The flowchart illustrates the integration of regulatory constraints into the AI-assisted recruitment screening process. It starts with 'Data and Feature Preprocessing' leading to 'Model Training and Evaluation'. With constraints, 'Risk Analysis & Data Governance' oversees 'Data and Feature Preprocessing (lawful, minimal, justified features only)'. 'Monitoring & Drift Detection' ensures 'Compliance is runtime, not only design-time'. 'Logging and Auditing' handles 'Compliance & Conformity Assess.' and 'May override Explain. & Transp. Interface'. 'Human-in-the-Loop Oversight' involves 'Integration with non-AI components (e.g., safeguards)'. 'Architectural Integration' leads to 'Model Validation and Testing' (Functional and non-functional testing), which then feeds back into 'Model Training' (Accuracy Within Risk Boundaries, Training constrained by explainability and fairness concerns).

Regulation as an Engineering Constraint

Engineering AI Under Regulatory Constraints: The Requirements Engineering Part

Example: AI-Assisted Recruitment Screening System, Implications

Some additional implications...

Regulation-Induced Trade-Offs

Regulation naturally induces multiple trade-offs. Again, accuracy alone is not enough.

Accuracy vs explainability

Automation vs human oversight

Performance vs compliance cost

The Digital Humanism Initiative

Technology profoundly shapes the world we live in, and the stakes are high. Digital Humanism deals with digital technology development and policies based on human rights, democracy, inclusion, and diversity.

About accuracy

“Good Enough” replaces “Best Possible”. Optimization is replaced by satisfaction under constraints.

The new life of traceability

Traceability is no longer a best practice, but a compliance mechanism.

AI may become unrealistic

Many “standard” AI architectures shown in classical AI courses are simply not deployable in regulated contexts.

AI cannot live without SE

As a matter of fact, there cannot be AI without SE. The diffusion of AI hinges on SE principles.



Software Engineering for Artificial Intelligence

Regulation as an Engineering Constraint

